

ITS67204

Professional Practices & Information Security

Scenario Based Individual Assessment

HAND OUT DATE: 7th January
HAND IN DATE: Week 13, 9th April
WEIGHTAGE: 40%

Instructions to students:

- This is an individual assessment
- Complete this cover sheet and attach it to your assessment – this should be your first page!
- Attach the Turnitin report with your assessment. Turnitin percentage should be < 20%.
- Failure to attach Turnitin report will result in your marks capped accordingly.

Student declaration:	
<i>I declare that:</i> ▪ <i>I understand what is meant by plagiarism</i> ▪ <i>The implication of plagiarism has been explained to me by my lecturer This assessment is all my work and I have acknowledged any use of the published or unpublished works of other people.</i>	
Name	Student ID
1. Ram Bahadur Bhandari	0362304

Avoid copy and paste job in your report and it is considered as plagiarism. Plagiarism in all forms is forbidden. Students who submit plagiarized assignment will be deserved a 0 marks.

Table of Contents

1. Introduction	1
2. Understanding of Risks and security Measures	1
2.1 Risks:	1
2.2 Security Measures:	2
3. Compliance with Data Protection Regulations	3
4. Addressing Ethical Challenges	4
5. Integration and Synthesis of Ideas	5
6. Conclusion.....	6
7. References:	7

1. Introduction

However, as different industries are integrating with the new technologies such as Artificial Intelligence (AI), Internet of Things (IoT), and blockchain technologies, it is increasingly provided smart fraud detection, real time device connectivity and transparent supply chain tracking. Transaction data is then going to be dug into, device data is going to be seen into by an AI based fraud detection system, IoT data in warehousing also included, and data is going to be fed in and transmitted and the blockchain platform is going to prevent unalterable data about supply chain. Similarly, they also introduce vulnerabilities like: data poisoning in AI, insecure communication in IoT, changing of transactions in blockchain, and GDPR and CCPA compliance. Besides privacy issues, ethical issues also impose a constraint on deployment, such as, do we risk flooding a person with a false alarm if he is intoxicated and wants to authenticate himself to see if they're committing fraud? This report has the aim of assessing these risks, suggesting a complete security framework, complying with all the regulatory compliance and dealing with ethical aspects and finally to develop a single solution fitting innovation with responsibility.

2. Understanding of Risks and security Measures

There are specific, yet entangled risks on the ecosystem's parts, and therefore, the details of the security required on each of them is quite different. The below describes every risk and every solution in detail:

2.1 Risks:

- **AI-Powered Fraud Detection:** Data poisoning targets the training set and consists of attackers introducing in the training sets (e.g., falsified transaction record) malicious data so that the training set will train the AI system to classify fraudulent activity as a legitimate one. For instance, a poisoned model would enable passing of a \$10,000 scam transaction and break the trust. As per Goodfellow et al. (2015), small (and usually subtle) changes to inputs, such as image pixels to adversarial attacks can be used to fool the model, too.

- ***IoT-Enabled Smart Devices:*** Data interception and hijacking of devices through insecure communication (e.g. unpatched firmware or weak encryption like outdated SSL) creates an insecure communication. The damage from a compromised IoT sensor could reach wider across the ecosystem as the AI relays false data to itself.
- ***Blockchain-Based Supply Chain:*** Double-spending, where digital asset is spent twice, or 51% attacks, where malicious entity controls most of network's computation power to write the ledger is included in transaction manipulation. The reentrancy bugs, which enabled the hackers to move to withdraw from the contract multiple times before a transaction updates, are some of the smart contract vulnerabilities that cause this.

2.2 Security Measures:

- ***AI:*** Anomaly detection algorithm (e.g., Isolation Forest) should be deployed to identify if data were poisoned, and filter them before training to avoid model corruption. Adversarial training consists of injecting examples perturbed to avoid attacks. Encrypt training data with a military standard AES-256 to keep them beyond the reach of unauthorized access. To flag abnormal real time predictions, tools like TensorFlow Model Analysis is used for runtime monitoring.
- ***IoT:*** Transport Layer Security (TLS) 1.3 ensuring data will not be visible in transit between the device and servers end to end. The system requires a firmware update through Over The Air (OTA) with digital signatures (e.g., RSA) for checking authentication and patching of various vulnerabilities. To segment the networks, VLANs are used to isolate so that if a compromised device does get in, it would not be able to achieve lateral movement and reach the AI or blockchain systems.
- ***Blockchain:*** Therefore, multi signature wallets should be used that require multiple approvals, such as approvals for a transaction requiring three of five keys to avoid such manipulation. However before deploying smart contracts it is considered a good practice to do smart contract audits using tools like Mythril or Oyente designed to find bugs. Instead of proof of work it will shift to proof of stake (PoS) consensus which does not make its users susceptible to 51% attacks, because it is more based on economic stakes compared to computational power (Kshetri, 2017).

These measures are put together in a single Security Operations Center (SOC) with threat detection using AI (e.g. IBM QRadar) to send real time alerts and appropriate responses on the ecosystem.

3. Compliance with Data Protection Regulations

These measures are put together in a single Security Operations Center (SOC) with threat detection using AI (e.g. IBM QRadar) to send real time alerts and appropriate responses on the ecosystem.

GDPR (European Union, 2016):

- ***Data Minimization and Purpose Limitation (Article 5):*** Log only what you need, such as shipment times only, or employee biometrics only if you need them. Through opt in prompts on device apps, they give explicit consent as to how the data is used ('only for fraud detection').
- ***Security of Processing (Article 32):*** Protect IoT and AI data at rest with AES-256 and in transit with TLS 1.3, to meet GDPR's standard for 'appropriately technical measures'. It also has SOC that monitors for unauthorized access and logs the incidents on the blockchain to be auditable.
- ***Breach Notification (Article 33):*** SOC alerts based on blockchain timestamps are used to automatically detect and report within 72 hours (e.g., "Breach detected: 01/04/2025, 14:32 GMT").
- ***Right to Erasure (Article 17):*** T1 Off-chain, store the personal data on a secure database with deletion protocols (e.g. cryptographic shredding), and allow the users to ask for deletion, verified by blockchain audit trails.

CCPA (California State Legislature, 2018):

- **Right to Know (Section 1798.100):** They also provide detailed data usage reports, such as “IoT data used for AI fraud analysis, stored 90 days” through blockchain logs, which are tamper proof and user accessible on request.
- **Right to Opt-Out (Section 1798.120):** Put IoT devices embedding opt out buttons into the device interfaces such as “Stop sharing my data”, stop selling the data to third party in real time and log the compliance on blockchain.
- **Data Security (Section 1798.150):** Encrypt and monitor in line with a sane interpretation of what CCPA says must be ‘reasonable security’ to avoid triggering private lawsuits against breaches. Regular penetration testing validates defenses.

Implementation Details: An appoint a Data Protection Officer (DPO) if necessary to monitor and ensure the organization is in compliance with the EU GDPR and perform quarterly audits to test the strength of encryption, checking for how long the organization has consent, and reporting time for breach response. Use toolings like OneTrust for consent management, blockchain to make records immutable so you are open and accountable on the possible ledger. Besides regulations requirements, this framework is even a complete offer to reduce legal risks and increase users’ trust.

4. Addressing Ethical Challenges

For instance, ethical concerns, especially with trivial application of facial recognition in detecting frauds, must be given detailed solutions.

- **Bias and Fairness:** If the training data is skewed, there doesn’t hurt the fault of it pouring into the AI models, which will just continue to flag that certain demographics for fraud. Although there are fairness metrics such as Demographic Parity, Equal Opportunity Difference, i.e., whether people (like the reporter) are treated differently from the specific dataset (such as the global transaction records), diversify the datasets to train and audit in the end. Text of the methodology: SHAP (Lundberg & Lee, 2017)

explainable AI tools assist in breaking down decisions into for instance “Transaction flagged for unusual timing, not user profile”, increasing transparency.

- **Privacy Protection:** Facial recognition raises surveillance risks. It can only be used in opt in scenarios (for example, "enable face ID for account security?") and anonymizes data with differential privacy by adding noise to data sets so that people’s identities are protected but the utility remains. Usage is logged to blockchain logs (e.g., ‘Facial data processed: 01/04/2025’), so an account is accountable but not personal.
- **Misuse Prevention:** Unless checked, facial recognition represents the possibility of mass tracking. Ban profiling without consent, and gather technologists, legal experts, and ethicists to form an ethics board to review use cases of the various apps in development. To maintain public trust, publish annual transparency reports e.g. ‘Facial recognition used in 5% of fraud cases and all opt - in’.

These measures guarantee an ecosystem that is ethical, by putting foremost fairness, user rights, and the good of society as compared to unbridled technological power.

5. Integration and Synthesis of Ideas

The framework integrates security, compliance, and ethics into a cohesive system:

- **Unified Architecture:** Components (IoT devices) encrypt the data with a TLS 1.3, as the AI fraud system feeds on the data and processes it securely while logging server results on the blockchain. AI is used on all layers by SOC to find the threats (e.g. poisoned data or IoT breach) and trigger responses (e.g. isolated the devices).
- **Cross-Functional Synergy:** GDPR/CCPA mandates for security are met by Encryption whilst also allowing for the ethical handling of the data (such as anonymized or aggregate facial recognition). Compliance (that is, opt out rights) and privacy goals are met through consent tools. In addition, the ethics board works with the DPO to have its policies, such as banning unfairness or unregulated AI models, align. Security, in this case, falls under the form of audit trails, compliance (proof of consent), and ethics (providing transparency).
- **Scalability and Future-Proofing:** The framework immediately converts into the modular one, being able to quickly adapt to assume quantum resistant cryptography

whenever quantum computing breaks through AES-256, or simply like it does with GDPR alterations. It is maintained as long term through regular stress tests and updates.

The consequence of this synthesis is that such an ecosystem is robust, compliant and ethical combining technological innovation with legal and moral imperatives.

6. Conclusion

It provides a complete security framework suitable for an AI, IoT, and blockchain ecosystem where it addresses risk such as data poisoning and manipulation on transactions, compliance to GDPR/CCPA, etc., and resolve ethical problems like misuse of facial recognition. The integrated solution ensures operations remain safeguarded protected and also helps to create trust and accountability.

7. References:

- California State Legislature. (2018). *California Consumer Privacy Act (CCPA)*. Civil Code § 1798.100-199. <https://leginfo.legislature.ca.gov>
- European Union. (2016). *General Data Protection Regulation (GDPR)*. Regulation (EU) 2016/679. <https://eur-lex.europa.eu/eli/reg/2016/679/oj>
- Goodfellow, I., Shlens, J., & Szegedy, C. (2015). Explaining and harnessing adversarial examples. *International Conference on Learning Representations*. <https://arxiv.org/abs/1412.6572>
- Kshetri, N. (2017). Blockchain's roles in strengthening cybersecurity and protecting privacy. *Telecommunications Policy*, 41(10), 1027-1038. <https://doi.org/10.1016/j.telpol.2017.09.003>
- Lundberg, S. M., & Lee, S.-I. (2017). A unified approach to interpreting model predictions. *Advances in Neural Information Processing Systems*, 30. <https://arxiv.org/abs/1705.07874>